PIPELINE RUN REPORT

AppSec Pipeline

Run 20261006-173842 | commit 9a4fe57 | 2026-10-06 17:38 UTC

2 passed, 1 blocked

Policy: Acme AppSec release gate (demo)

Release policy

Critical and high findings block the release unless a dated waiver exists in the app's appsec.json. More than max_medium medium findings also blocks. Manual-review findings are tracked in the review report, not by the pipeline.

Stages

Stage	What it does	Production equivalent
Inventory	Enumerate files, languages and manifests	-
Secret scan	Regex rules for keys, tokens and credentials	gitleaks-style
SAST	AST rules for injection, crypto and misconfiguration	Semgrep/CodeQL-style
Dependency scan	Pinned packages vs. advisory data	pip-audit/Dependabot-style
IaC scan	Terraform misconfiguration	Checkov/tfsec-style
Container scan	Dockerfile hygiene	Hadolint/Trivy-style
SBOM	CycloneDX 1.5 bill of materials	Syft-style
DAST	Starts the app and probes it over HTTP	ZAP-style
Release gate	Applies policy.json and dated waivers	-

Acme Inventory API

Gate: PASS. No blocking findings.

Open findings: 0 critical, 0 high, 0 medium, 0 low. Duration 143 ms across 9 stages.

No findings in any stage.

Acme Leave Tracker

Gate: PASS. No blocking findings.

Open findings: 0 critical, 0 high, 4 medium, 2 low. Duration 115 ms across 9 stages.

Severity	Stage	Rule	Location	Detail
MEDIUM	sast	SAST-INSECURE-RANDOM	app.py:27	random.choice inside new_reset_token()
MEDIUM	sast	SAST-VERBOSE-ERRORS	app.py:67	exception text returned in the response
MEDIUM	sast	SAST-COOKIE-FLAGS	app.py:71	missing Secure, HttpOnly
MEDIUM	sca	SCA-VULNERABLE-DEPENDENCY	requirements.txt:1	requests 2.25.1: Proxy-Authorization header leaked to the destination server on HTTPS redirects. (CVE-2023-32681). Fixed in 2.31.0.
LOW	container	DOCKER-NO-HEALTHCHECK	Dockerfile:1	-
LOW	dast	DAST-MISSING-HEADERS	GET /health	missing: X-Frame-Options, Content-Security-Policy

Acme Payments Portal

Gate: FAIL. 6 critical finding(s); 8 high finding(s); 7 medium findings exceed the limit of 5

Open findings: 6 critical, 8 high, 7 medium, 3 low. Duration 116 ms across 9 stages.

Severity	Stage	Rule	Location	Detail
CRITICAL	dast	DAST-SQLI	GET /search	parameter 'q': a lone quote produced a database error
CRITICAL	sast	SAST-SQLI	app.py:30	query assembled with string formatting
CRITICAL	sast	SAST-CMDI	app.py:59	os.system with a non-constant command
CRITICAL	sca	SCA-VULNERABLE-DEPENDENCY	requirements.txt:1	pyyaml 5.3: Arbitrary code execution via yaml.full_load / FullLoader on untrusted input. (CVE-2020-14343). Fixed in 5.4.
CRITICAL	secrets	SEC-AWS-ACCESS-KEY	app.py:14	value redacted
CRITICAL	secrets	SEC-AWS-SECRET	app.py:15	value redacted
HIGH	dast	DAST-UNAUTH-ACCESS	GET /admin	HTTP 200 with no credentials
HIGH	dast	DAST-PATH-TRAVERSAL	GET /download	parameter 'file' returned file content for ../../../../../../../../../etc/passwd
HIGH	iac	IAC-S3-PUBLIC-ACL	infra/main.tf:1	aws_s3_bucket.exports
HIGH	iac	IAC-SG-OPEN-ADMIN-PORT	infra/main.tf:10	aws_security_group.portal ports 22-22
HIGH	sast	SAST-PATH-TRAVERSAL	app.py:34	open() on a path derived from parameter(s) name
HIGH	sca	SCA-VULNERABLE-DEPENDENCY	requirements.txt:2	requests 2.19.0: Authorization header sent to a different host after a redirect. (CVE-2018-18074). Fixed in 2.20.0.
HIGH	sca	SCA-VULNERABLE-DEPENDENCY	requirements.txt:3	jinja2 2.10: Sandbox escape through str.format_map. (CVE-2019-10906). Fixed in 2.10.1.
HIGH	secrets	SEC-HARDCODED-SECRET	app.py:13	value redacted
MEDIUM	container	DOCKER-ROOT	Dockerfile:1	no non-root USER
MEDIUM	iac	IAC-RDS-UNENCRYPTED	infra/main.tf:24	aws_db_instance.ledger
MEDIUM	sast	SAST-WEAK-HASH	app.py:25	hashlib.md5
MEDIUM	sast	SAST-VERBOSE-ERRORS	app.py:67	exception text returned in the response
MEDIUM	sast	SAST-WEAK-HASH	app.py:74	hashlib.md5
MEDIUM	sast	SAST-COOKIE-FLAGS	app.py:78	missing Secure, HttpOnly
MEDIUM	sca	SCA-VULNERABLE-DEPENDENCY	requirements.txt:2	requests 2.19.0: Proxy-Authorization header leaked to the destination server on HTTPS redirects. (CVE-2023-32681). Fixed in 2.31.0.
LOW	container	DOCKER-LATEST	Dockerfile:1	python:latest
LOW	container	DOCKER-NO-HEALTHCHECK	Dockerfile:1	-
LOW	dast	DAST-MISSING-HEADERS	GET /health	missing: X-Content-Type-Options, X-Frame-Options, Content-Security-Policy